03 - Risk Analysis

Project: Applying GRC Risk Management to an Electronic Patient Information System at a Fictional Private Hospital in Jordan

1. Objective

The objective of this document is to analyze the risks identified for the Electronic Patient Information System by examining their potential causes, scenarios, consequences, likelihood, and impact.

The results of this stage will provide the necessary input for the Risk Evaluation and Risk Treatment stages.

2. Scope

This analysis covers risks associated with the Electronic Patient Information System and its defined functions:

- Patient registration.
- Appointment management.
- Storage and retrieval of medical records.
- User account and access permission management.
- Cloud hosting and the database supporting the system.

Other hospital systems and operations are outside the scope of this analysis.

3. Risk Analysis Methodology

Each identified risk will be analyzed using the following elements:

1. **Related Assets:** Assets that may be affected by the identified risk.
2. **Potential Causes:** Conditions or events that could contribute to the risk occurring.
3. **Risk Scenario:** A description of how the risk could materialize.
4. **Potential Consequences:** Possible effects if the risk occurs.
5. **Affected CIA Objectives:** Confidentiality, Integrity, and Availability objectives that may be affected.

6. **Likelihood Analysis:** An assessment of how likely the risk scenario is to occur.
7. **Impact Analysis:** An assessment of the potential consequences for the affected CIA objectives.
8. **Evidence and Information Gaps:** Available information, supporting evidence, and details requiring further verification.

Potential causes and consequences are considered possible scenarios and do not indicate that a vulnerability, incident, or missing security control has been confirmed.

4. Likelihood Analysis

Likelihood represents the possibility of a risk scenario occurring.

The assessment considers relevant threats, system exposure, potential vulnerabilities, and the effectiveness of existing controls where supporting information is available.

The following qualitative levels will be used:

Level	Description
Low	The event is unlikely, with no strong indicators suggesting that it is likely to occur.
Medium	The event is possible, and relevant conditions could allow it to occur.
High	The event is likely due to identified weaknesses, exposure, or other enabling conditions.
Very High	Strong indicators suggest imminent or repeated occurrence, or the event is very likely.

5. Impact Analysis

Impact represents the potential consequences of a risk scenario on the system and its information.

The assessment considers the following security objectives:

- **Confidentiality:** Potential unauthorized disclosure or access to patient information.
- **Integrity:** Potential unauthorized, incorrect, or accidental modification or deletion of information.
- **Availability:** Potential disruption or loss of access to the system and its information.

The following impact levels will be used:

Level	Description
Low	Limited impact with no significant disruption or damage to the system or its information.
Medium	Noticeable impact, such as a limited information error or temporary disruption affecting some tasks.
High	Major impact, such as disclosure of sensitive information, loss of important data, or significant service disruption.
Critical	Very severe impact, such as widespread exposure of sensitive information, loss of essential data, or a major outage threatening service continuity.

Where a risk affects multiple CIA objectives, each relevant impact will be considered. The overall impact will be based on the most severe material impact, with its justification documented.

Final risk levels will be determined during the Risk Evaluation stage using the approved Risk Assessment Matrix.

6. Risk Analysis Table

The following table provides the initial analysis of the risks identified during the Risk Identification stage.

Likelihood and Impact remain pending until sufficient supporting information is available. Their final levels will be determined through the assessment process.

Risk ID	Related Assets	Potential Causes	Potential Consequences	Affected CIA Objectives	Likelihood	Impact
R-01	A-02, A-03, A-05, A-06, A-07	Stolen credentials, improper access configuration, exploitation of system vulnerabilities	Unauthorized disclosure of patient information and possible misuse of exposed data	Confidentiality; potentially Integrity and Availability	Pending	Pending
R-02	A-01, A-05,	Incorrect permission assignment,	Unauthorized access to information or	Confidentiality, Integrity	Pending	Pending

	A-02, A-03	unclear user roles, lack of access reviews	system functions and possible unauthorized modifications			
R-03	A-05, A-01, A-02, A-03	Phishing, password reuse, credential sharing, insecure password storage	Account compromise and unauthorized access to patient information or system functions	Confidentiality, Integrity; potentially Availability	Pending	Pending
R-04	A-05, A-01, A-02, A-03	Delayed account deactivation, incomplete staff notifications, unclear account management responsibilities	Unauthorized access through accounts that should no longer be active	Confidentiality, Integrity	Pending	Pending
R-05	A-05, A-02, A-03, A-06	Insider misuse, excessive permissions, inadequate monitoring	Unauthorized access to or modification of patient information by an authorized user	Confidentiality, Integrity	Pending	Pending
R-06	A-02, A-03, A-05, A-06	User error, unauthorized access, application errors, inadequate change controls	Incorrect or unauthorized modification of patient information and medical records	Integrity; potentially Availability	Pending	Pending

R-07	A-03, A-06, A-09	Accidental deletion, malicious deletion, system failure, data corruption	Loss of important medical records and inability to retrieve required information	Integrity, Availability	Pending	Pending
R-08	A-06, A-09, A-07	Missing backups, backup failures, incomplete copies, untested restoration procedures	Inability to restore important information following data loss or system failure	Integrity, Availability	Pending	Pending
R-09	A-02, A-03, A-04, A-06	Unauthorized copying, insecure transfer, incorrect recipient, misdirected communication	Disclosure of patient information to unauthorized external recipients	Confidentiality	Pending	Pending
R-10	A-05, A-01, A-02, A-03	Deceptive emails, inadequate user awareness, impersonation, insufficient email protections	Stolen credentials, account compromise, or disclosure of sensitive information	Confidentiality, Integrity; potentially Availability	Pending	Pending
R-11	A-01, A-02, A-03, A-06,	Malicious attachments, compromised credentials, exploited	Encryption of data, loss of system access, operational	Availability, Integrity; potentially Confidentiality	Pending	Pending

	A-07, A-09	vulnerabilities, malware propagation	disruption, and possible data exposure			
R-12	A-01, A-06, A-07	Unpatched software, insecure configuration, vulnerable components, inadequate vulnerability management	Unauthorized access, data exposure or modification, and system disruption	Confidentiality, Integrity, Availability	Pending	Pending
R-13	A-01, A-07	Excessive malicious traffic, abuse of exposed services, insufficient traffic protection	System unavailability or degraded performance preventing users from accessing required functions	Availability	Pending	Pending
R-14	A-01, A-05, A-06, A-07	Infected files, malicious downloads, compromised software, exploited vulnerabilities	Unauthorized disclosure or modification of information and disruption of system operations	Confidentiality, Integrity, Availability	Pending	Pending
R-15	A-07, A-01, A-06	Cloud provider outage, infrastructure failure, connectivity disruption	System unavailability and interruption of patient registration, appointments, and medical record access	Availability	Pending	Pending
R-16	A-08, A-07,	Stolen administrative credentials,	Unauthorized control of cloud	Confidentiality, Integrity, Availability	Pending	Pending

	A-06, A-01	weak authentication, excessive privileges, insecure account configuration	resources, potentially resulting in data exposure, modification, deletion, or service disruption			
R-17	A-01, A-06, A-07	Hardware failure, software malfunction, database failure, configuration errors	System or component failure preventing users from accessing required functions	Availability; potentially Integrity	Pending	Pending
R-18	A-01, A-05, A-06, A-07	Insufficient logging, lack of monitoring, unclear alert ownership, delayed incident escalation	Delayed incident detection and response, allowing the incident and its impact to increase	Confidentiality, Integrity, Availability	Pending	Pending

7. Evidence and Information Gaps

The following information should be reviewed where available to validate the analysis:

- User roles and permission definitions.
- Account creation, modification, review, and deactivation procedures.
- Authentication requirements and access logs.
- System architecture and technical configuration.
- Vulnerability assessment and security testing results.
- Backup configuration and restoration test records.
- Cloud service agreement and provider responsibilities.
- Monitoring, logging, and incident response procedures.
- Previous incidents and operational problem records.

The absence of available information must not automatically be interpreted as evidence that a security control is absent or ineffective.

Information gaps should be documented and addressed during the relevant assessment and review activities.

8. Analysis Outputs

The outputs of this stage include:

- An initial analysis of the identified risks.
- Identification of related assets for each risk.
- Documentation of potential causes and consequences.
- Identification of affected CIA objectives.
- Identification of evidence and information gaps.
- Inputs required for the Risk Evaluation stage.

This document does not determine whether risks are acceptable or select treatment options. These decisions will be addressed in the subsequent Risk Evaluation and Risk Treatment stages.